Atenção

Todas as técnicas discutidas nesta disciplina tem objetivo estritamente EDUCACIONAL e devem ser usadas apenas para melhorar a defesa das aplicações e sistemas.

1 · Arquivo sensível exposto



Um arquivo de backup esquecido no servidor, acessível pela web, entrega uma senha real.

2 · Página de debug exposta



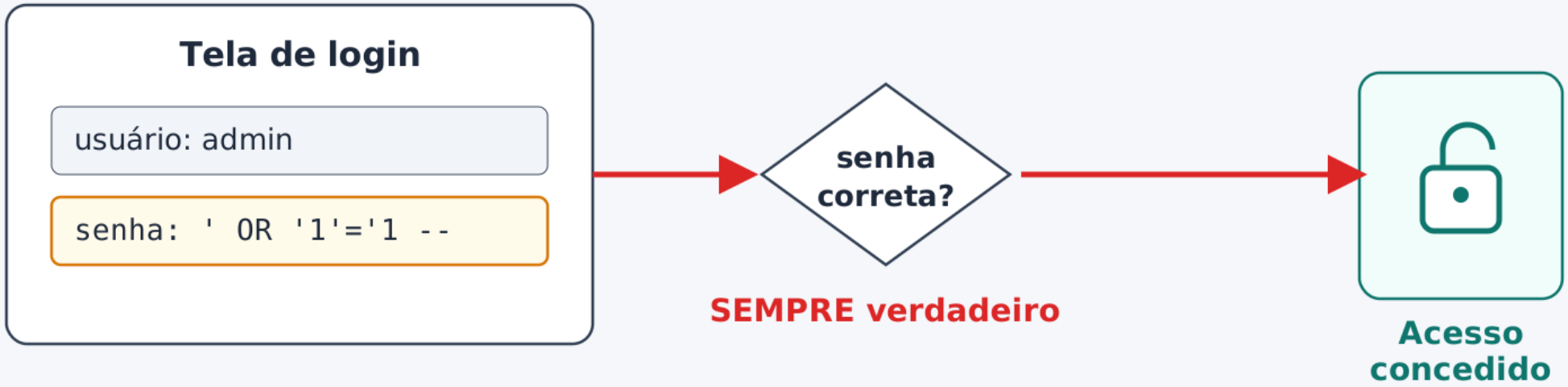
Uma página interna, sem link e sem senha, entrega detalhes que ajudam os próximos ataques.

3 · SQL Injection



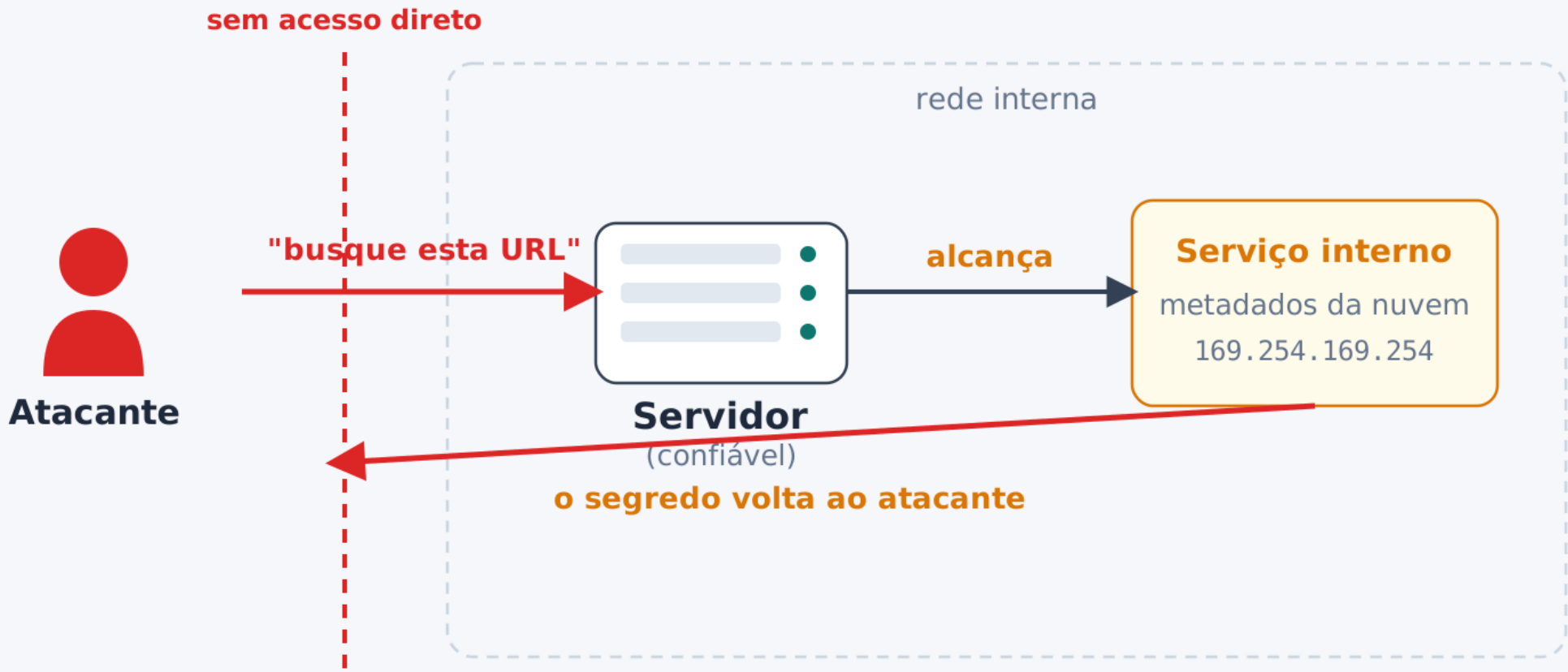
O texto digitado é grudado na consulta SQL e passa a fazer parte do comando.

4 · Bypass de login



A injeção torna a verificação de senha sempre verdadeira — entra sem credencial válida.

5 · SSRF — o servidor busca por você



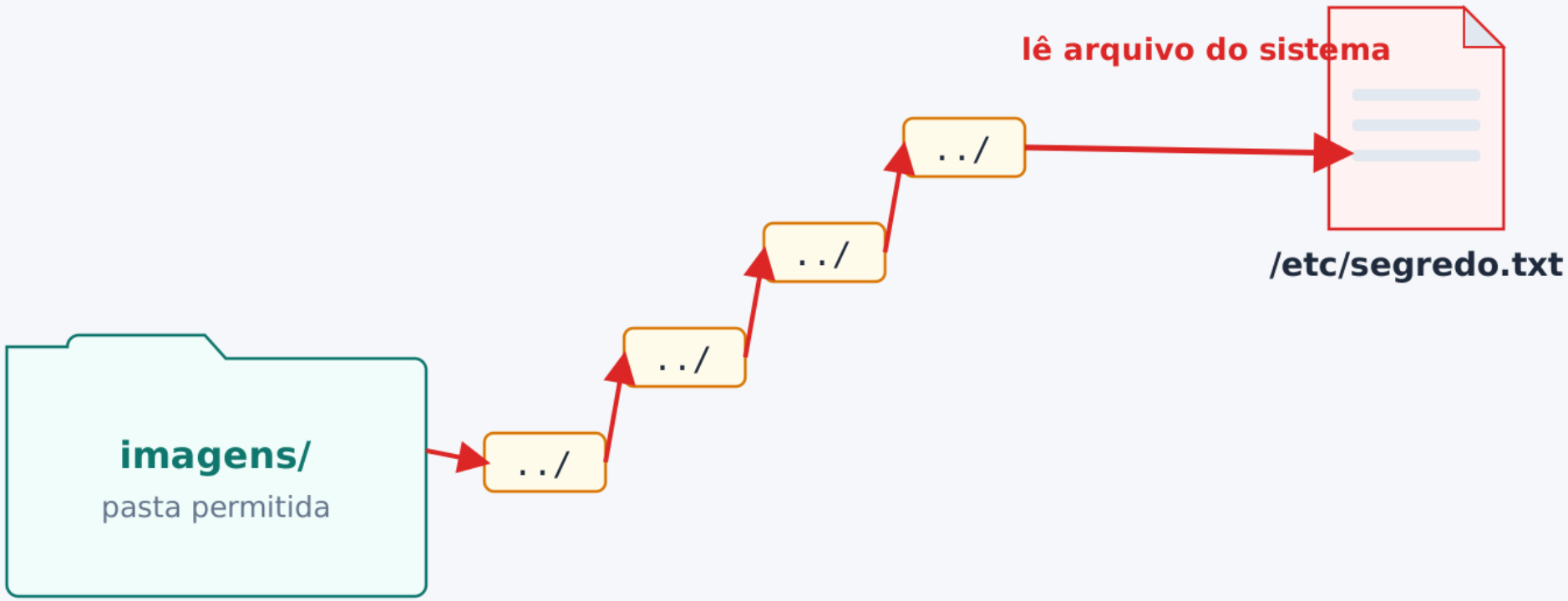
O atacante não alcança o recurso interno, mas pede ao servidor — que está dentro e alcança.

6 · Objeto público no S3



Armazenamento marcado como público: qualquer um com o endereço baixa o conteúdo.

7 · Path traversal



Com ../ o pedido sobe de pasta e sai da área permitida, lendo arquivos de qualquer lugar.